

The Phone Boss ULTD Information Security Policy Pack

Policy framework for repair refurbishment sales technical support and online operations

This policy pack establishes the minimum information-security requirements The Phone Boss ULTD will apply after formal approval. It protects customer devices, customer information, business accounts, records, websites, payment activities, and supplier-supported services. The pack is proportionate to a sole-owner business and must be updated as services, technology, staffing, and legal obligations change.

The policies convert the organization's risk assessment and Statement of Applicability into operating requirements. Some requirements formalize existing practices; others establish actions that must be implemented and evidenced. The document does not claim ISO IEC 27001 certification or complete conformity.

Document status

Owner	Richard Vincent
Approval authority	Richard Vincent
Version	1.0
Approval date	To be completed
Effective date	Upon formal approval

Policies included

- ISP 001 Information Security Policy
- ACP 001 Access Control and Authentication Policy
- DHP 001 Customer Device and Information Handling Policy
- IRP 001 Incident Response and Reporting Policy
- BCP 001 Backup and Business Continuity Policy
- SUP 001 Supplier Security Policy

Policy register and approval

The register provides one place to record formal approval and track the annual review cycle. Each policy becomes effective only after the approval date is entered.

Policy ID	Policy title	Owner	Approval date	Status
ISP 001	Information Security Policy	Richard Vincent	To be completed	Pending approval
ACP 001	Access Control and Authentication Policy	Richard Vincent	To be completed	Pending approval
DHP 001	Customer Device and Information Handling Policy	Richard Vincent	To be completed	Pending approval
IRP 001	Incident Response and Reporting Policy	Richard Vincent	To be completed	Pending approval
BCP 001	Backup and Business Continuity Policy	Richard Vincent	To be completed	Pending approval
SUP 001	Supplier Security Policy	Richard Vincent	To be completed	Pending approval

Approval record

By approving this pack, the owner adopts the requirements for the business and accepts responsibility for implementation, evidence retention, exception approval, and continual improvement.

Approved by Richard Vincent: _____

Signature: _____

Approval date: _____

Information Security Policy

Policy ID	ISP 001	Owner	Richard Vincent
Version	1.0	Approval authority	Richard Vincent
Approval date	To be completed	Effective date	Upon formal approval
Review cycle	Annually and after significant changes or incidents	Next review	12 months after approval

This policy establishes management direction for protecting information and managing security risk across The Phone Boss ULTD.

Purpose

Protect the confidentiality, integrity, and availability of customer and business information through risk-based, documented, and reviewable security practices.

Scope

Applies to repair, refurbishment, sales, technical support, onsite service, home-workspace activities, online operations, customer devices in custody, business endpoints, paper and digital records, critical accounts, websites, payment activities, and suppliers supporting these services. Planned cybersecurity and secure-AI advisory services remain subject to separate prelaunch approval.

Policy requirements

- Richard Vincent is accountable for information security, risk acceptance, policy approval, and resource decisions.
- Security risks must be recorded, assigned an owner, treated, and reviewed at least annually and after material changes or incidents.
- Access to customer and business information must be limited to authorized business need.
- Customer devices and information must be protected throughout intake, transport, repair, storage, testing, return, retention, and disposal.
- Security incidents and suspected privacy breaches must be recorded and assessed immediately.
- Critical records and services must have appropriate backup, recovery, and continuity arrangements.
- Critical suppliers must be assessed in proportion to the information and services they support.
- Security evidence must be accurate, protected, retrievable, and retained for the applicable business or legal need.
- New workers, contractors, technologies, or advisory services must not receive access or launch until applicable security requirements are defined and approved.

Responsibilities

Richard Vincent maintains the policies, performs reviews, records risks and incidents, approves exceptions, and verifies corrective actions. Any future worker or contractor must follow applicable requirements and report suspected incidents immediately.

Evidence and records

- Approved policies and revision history
- Risk register and treatment plan
- Statement of Applicability

- Management review notes
- Exception and corrective-action records

Related controls and risks

ISO IEC 27001 Annex A controls: A.5.1, A.5.2, A.5.4

Risk register references: All current information-security risks

Exceptions

Any exception must document the affected requirement, business justification, associated risk, compensating controls, owner, approval by Richard Vincent, and a review or expiration date. Approval does not replace implementation and verification of compensating controls.

Compliance and review

The policy owner will review this policy annually and after significant business, technology, supplier, staffing, legal, or incident changes. Identified noncompliance will be recorded, corrected, and tracked through the corrective-action process.

Access Control and Authentication Policy

Policy ID	ACP 001	Owner	Richard Vincent
Version	1.0	Approval authority	Richard Vincent
Approval date	To be completed	Effective date	Upon formal approval
Review cycle	Annually and after significant changes or incidents	Next review	12 months after approval

This policy governs access to devices, customer information, business records, email, payments, websites, domains, repositories, cloud services, and administrative accounts.

Purpose

Prevent unauthorized access and ensure that accounts and privileges match current business responsibilities.

Scope

Applies to all business devices, customer information, critical accounts, cloud services, payment portals, websites, domains, source repositories, backup locations, and any future user or contractor access.

Policy requirements

- Each user must have an individually attributable account where the service supports it. Shared access must be avoided unless technically necessary and formally approved.
- Critical business accounts must use MFA. Stronger phishing-resistant methods should be used when available and practical.
- Passwords must be unique, securely stored, and not reused across critical accounts.
- Recovery email addresses, telephone numbers, backup codes, security keys, active sessions, and connected integrations must be protected and reviewed.
- Devices must use a password, PIN, or biometric control, encryption, automatic security updates, endpoint protection, automatic locking, backup, and remote lock or wipe where supported.
- Administrative privileges must be limited to business need. Routine activity should not use elevated access when separation is available.
- Access to critical accounts must be reviewed every six months and after suspected compromise, major platform or integration changes, and before or after granting access to any future worker or contractor.
- Access must be removed promptly when no longer required. Credentials must never be transferred informally to support business continuity.

Access review procedure

1. Reconcile the account list with current business needs.
2. Review privilege levels, MFA, recovery methods, active sessions, devices, API keys, and integrations.
3. Remove unnecessary access and investigate unknown activity.
4. Record the reviewer, date, findings, actions, and completion evidence.

Evidence and records

- Critical-account inventory
- MFA and recovery-setting evidence
- Password-manager review record without exposing passwords

- Active-session and integration review
- Six-month access-review record
- Onboarding and offboarding records

Related controls and risks

ISO IEC 27001 Annex A controls: A.5.15, A.5.16, A.5.18, A.8.1, A.8.2, A.8.5

Risk register references: R-02, R-04, R-06

Exceptions

Any exception must document the affected requirement, business justification, associated risk, compensating controls, owner, approval by Richard Vincent, and a review or expiration date. Approval does not replace implementation and verification of compensating controls.

Compliance and review

The policy owner will review this policy annually and after significant business, technology, supplier, staffing, legal, or incident changes. Identified noncompliance will be recorded, corrected, and tracked through the corrective-action process.

Customer Device and Information Handling Policy

Policy ID	DHP 001	Owner	Richard Vincent
Version	1.0	Approval authority	Richard Vincent
Approval date	To be completed	Effective date	Upon formal approval
Review cycle	Annually and after significant changes or incidents	Next review	12 months after approval

This policy protects customer devices and information from intake through return or approved disposal.

Purpose

Maintain custody, confidentiality, integrity, and accountability when handling customer devices, customer information, receipts, and temporary credentials.

Scope

Applies to devices received at customer locations or the home workspace, devices transported for repair, onsite work, physical and digital receipts, repair notes, contact information, temporary passcodes, and testing activities.

Policy requirements

- Obtain customer authorization and create an intake record identifying the customer, device, requested work, observable condition, custody date, and return status.
- Keep customer devices under the owner's control during transport, repair, testing, and storage.
- When a device remains overnight, record the device, reason, storage location, custody status, and eventual return. Store it in a secured location accessible only to the owner.
- Request a customer passcode only when authorized testing requires it. Avoid collecting a passcode when the repair can be validated without it.
- Limit passcode access to Richard Vincent. Do not make unnecessary digital copies or retain the passcode beyond testing.
- Shred or securely destroy the temporary passcode record immediately after testing and confirm destruction on the repair record.
- Access only the functions and information necessary to complete authorized testing.
- Return devices through a documented handoff. Record loss, damage, suspected unauthorized access, or missing custody evidence as an incident immediately.
- Retain customer and business records only as long as required for business, warranty, accounting, legal, or contractual purposes. Securely delete or destroy records when the approved need ends.
- Do not store complete payment-card numbers. Use approved payment providers for card processing.

Privacy requests and disclosure

Customer information must not be disclosed except to the customer, an authorized recipient, an approved service provider with a legitimate need, or as legally required. Identity and authority must be reasonably verified before disclosure or return.

Evidence and records

- Customer authorization and intake records
- Custody and overnight-device logs

- Return confirmations
- Passcode-destruction confirmation
- Retention and secure-deletion records
- Incident and customer-communication records

Related controls and risks

ISO IEC 27001 Annex A controls: A.5.12, A.5.13, A.5.33, A.5.34, A.7.9, A.8.10

Risk register references: R-01, R-06, R-07, R-09

Exceptions

Any exception must document the affected requirement, business justification, associated risk, compensating controls, owner, approval by Richard Vincent, and a review or expiration date. Approval does not replace implementation and verification of compensating controls.

Compliance and review

The policy owner will review this policy annually and after significant business, technology, supplier, staffing, legal, or incident changes. Identified noncompliance will be recorded, corrected, and tracked through the corrective-action process.

Incident Response and Reporting Policy

Policy ID	IRP 001	Owner	Richard Vincent
Version	1.0	Approval authority	Richard Vincent
Approval date	To be completed	Effective date	Upon formal approval
Review cycle	Annually and after significant changes or incidents	Next review	12 months after approval

This policy establishes a consistent process for responding to suspected information-security and privacy incidents.

Purpose

Reduce harm through prompt identification, assessment, containment, evidence preservation, communication, recovery, and corrective action.

Scope

Applies to customer devices, temporary credentials, business endpoints, critical accounts, websites, cloud services, payments, suppliers, paper and digital records, and any event that could affect confidentiality, integrity, or availability.

Reportable events

- Lost, stolen, damaged, or unaccounted-for customer or business devices
- Suspected unauthorized access, malware, phishing, account takeover, or credential exposure
- Lost or improperly retained customer passcodes
- Data sent to the wrong person or disclosed without authorization
- Website, payment, email, backup, or cloud-service disruption with material business impact
- Supplier incidents that could affect business services or customer information
- Failure of a required security control or evidence of repeated noncompliance

Response requirements

- Record and begin assessing the event immediately after discovery.
- Protect people and property, then contain affected devices, accounts, information, or services without unnecessarily destroying evidence.
- Preserve relevant logs, messages, screenshots, receipts, device records, timestamps, and communications.
- Determine affected information, customers, services, time period, and likely impact.
- Escalate to providers, insurers, customers, law enforcement, regulators, or other authorities according to applicable legal and contractual requirements. Do not make unsupported breach claims.
- Recover services, validate security, and monitor for recurrence.
- Document decisions, communications, recovery evidence, root cause, lessons learned, and corrective actions.

Authority

Richard Vincent serves as incident coordinator and authorizes customer, insurer, provider, legal, and regulatory communications. External professional assistance must be obtained when the incident exceeds internal capability or creates material legal, privacy, safety, or financial exposure.

Evidence and records

- Incident log and chronology
- Preserved evidence index
- Containment and recovery records
- Notification assessment and communications
- Root-cause analysis
- Corrective-action record and closure evidence
- Tabletop exercise results

Related controls and risks

ISO IEC 27001 Annex A controls: A.5.24, A.5.25, A.5.26, A.5.27, A.5.28

Risk register references: R-01, R-02, R-05, R-06, R-07, R-08, R-09

Exceptions

Any exception must document the affected requirement, business justification, associated risk, compensating controls, owner, approval by Richard Vincent, and a review or expiration date. Approval does not replace implementation and verification of compensating controls.

Compliance and review

The policy owner will review this policy annually and after significant business, technology, supplier, staffing, legal, or incident changes. Identified noncompliance will be recorded, corrected, and tracked through the corrective-action process.

Backup and Business Continuity Policy

Policy ID	BCP 001	Owner	Richard Vincent
Version	1.0	Approval authority	Richard Vincent
Approval date	To be completed	Effective date	Upon formal approval
Review cycle	Annually and after significant changes or incidents	Next review	12 months after approval

This policy supports timely restoration of critical records and continued customer service during technology, supplier, website, or owner-availability disruptions.

Purpose

Maintain recoverable information, documented recovery steps, and practical alternatives for critical services.

Scope

Applies to business and customer-service records, receipts, websites, repositories, email, domain and hosting information, cloud platforms, payment activities, recovery credentials, active repair records, and emergency customer communication.

Backup requirements

- Back up critical business records at least weekly and before major migrations or configuration changes.
- Protect backup access with appropriate authentication and restrict it to the owner or a formally authorized recovery person.
- Keep recovery information sufficient to locate backups, restore data, and regain access to critical providers. Do not record live passwords in an unsecured continuity document.
- Test restoration at least annually and after significant migrations. Record the test date, information restored, result, problems, and corrective actions.
- Complete and document website restoration testing following the current migration.
- Protect backups and recovery records against unauthorized access, alteration, and unnecessary retention.

Continuity requirements

- Maintain an up-to-date list of active customer devices and repair jobs.
- Document customer-contact and device-return steps for prolonged owner unavailability.
- Maintain alternative communication and payment methods for provider outages.
- Record critical providers, support channels, account-recovery information, and replacement options.
- Authorize a trusted person through a documented arrangement where necessary. Do not share passwords informally.
- Review continuity steps after exercises, real disruptions, major provider changes, or changes in business operations.

Evidence and records

- Backup completion records
- Successful restoration results
- Website files and migration records
- Website recovery test

- Continuity and emergency-access instructions
- Active-job inventory
- Alternative communication and payment instructions
- Exercise and corrective-action records

Related controls and risks

ISO IEC 27001 Annex A controls: A.5.29, A.5.30, A.8.13, A.8.14

Risk register references: R-03, R-05, R-08

Exceptions

Any exception must document the affected requirement, business justification, associated risk, compensating controls, owner, approval by Richard Vincent, and a review or expiration date. Approval does not replace implementation and verification of compensating controls.

Compliance and review

The policy owner will review this policy annually and after significant business, technology, supplier, staffing, legal, or incident changes. Identified noncompliance will be recorded, corrected, and tracked through the corrective-action process.

Supplier Security Policy

Policy ID	SUP 001	Owner	Richard Vincent
Version	1.0	Approval authority	Richard Vincent
Approval date	To be completed	Effective date	Upon formal approval
Review cycle	Annually and after significant changes or incidents	Next review	12 months after approval

This policy governs the selection, use, monitoring, and exit of suppliers that support information processing or critical business services.

Purpose

Identify and manage information-security, privacy, availability, and dependency risks arising from suppliers.

Scope

Applies to Zoho, Cloudflare, GitHub, Stripe, domain registrars, hosting platforms, backup services, communications providers, repair subcontractors, software services, and future suppliers that access information or support critical operations.

Supplier classification

A supplier is critical when its failure, compromise, or loss of access could materially interrupt customer service, expose sensitive information, affect payments, disable online services, or prevent recovery.

Policy requirements

- Record each critical supplier, service purpose, information accessed, business owner, dependency, security features, support route, renewal terms, recovery method, and exit option.
- Review critical suppliers before selection, at least annually, after significant security or service incidents, after material contract changes, and when the supplier begins processing different information.
- Use MFA and least-privilege access for supplier accounts where supported. Review account recovery, active sessions, connected integrations, and authorized users.
- Assess relevant privacy, breach-notification, service-availability, backup, recovery, data-return, deletion, and termination arrangements.
- Retain relevant agreements, security documentation, review results, incidents, insurance information, and treatment decisions.
- Do not assume that a recognized brand eliminates supplier risk. Apply review depth according to data sensitivity and business impact.
- Maintain reasonable alternatives or recovery arrangements for critical supplier failure.
- Record supplier incidents and follow the Incident Response and Reporting Policy.

Payment providers

Approved payment providers must process full card details. The Phone Boss ULTD must not store complete card numbers. Payment activity, integrations, alerts, unusual transactions, and disputes must be reviewed and retained according to business and legal needs.

Evidence and records

- Supplier inventory and classification

- Supplier review records
- Agreements and relevant security documentation
- MFA, recovery, session, and integration evidence
- Provider incident and availability records
- Insurance and dispute documentation
- Exit and recovery information

Related controls and risks

ISO IEC 27001 Annex A controls: A.5.19, A.5.20, A.5.21, A.5.22, A.5.23

Risk register references: R-02, R-05, R-08, R-09

Exceptions

Any exception must document the affected requirement, business justification, associated risk, compensating controls, owner, approval by Richard Vincent, and a review or expiration date. Approval does not replace implementation and verification of compensating controls.

Compliance and review

The policy owner will review this policy annually and after significant business, technology, supplier, staffing, legal, or incident changes. Identified noncompliance will be recorded, corrected, and tracked through the corrective-action process.

Implementation and evidence checklist

Use this checklist after approval to convert each policy requirement into operating evidence. Mark an item complete only after the evidence is reviewed and retained.

Priority action	Owner	Status	Closure evidence
Enter approval and effective dates	Richard Vincent	Planned	To be completed
Create consolidated asset and account inventories	Richard Vincent	Planned	To be completed
Complete critical-account access review	Richard Vincent	Planned	To be completed
Document and test incident response	Richard Vincent	Planned	To be completed
Complete website restoration test	Richard Vincent	Planned	To be completed
Document continuity and emergency-access steps	Richard Vincent	Planned	To be completed
Create supplier register and perform initial reviews	Richard Vincent	Planned	To be completed
Create retention and secure-deletion schedule	Richard Vincent	Planned	To be completed
Implement overnight-device custody log	Richard Vincent	Planned	To be completed
Collect endpoint-control evidence	Richard Vincent	Planned	To be completed

Portfolio use: This pack demonstrates policy drafting, risk-to-control traceability, evidence planning, exception governance, and practical ISO IEC 27001 implementation for a small business. It must not be presented as proof of certification.